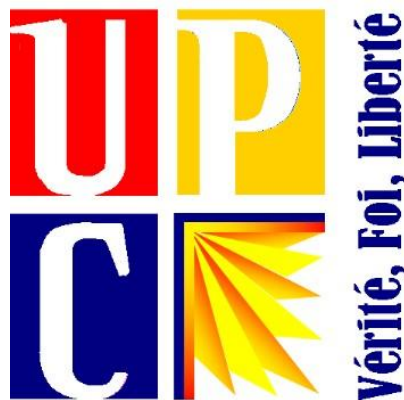




UNIVERSITÉ PROTESTANTE AU CONGO

TP DE PROGRAMMATION POUR LA CYBER SECURITE

3^{ème} licence Sécurité Informatique

Etudiant : MAMBWIYA MIPANGU MERDI, MUKWAYA WA
MUKWAYA DANIEL, LAMBA MANZENGELE JESSE,
NGWANZA ODZAT DANIEL, MIANDA Kalonji HULDA

ANNEE ACADEMIQUE: 2025-2026

TP1 – Renifleur de Réseau et Capture de Credentials en Clair

Questions de compréhension – Partie A

1. Définissez le concept de filtre BPF. Donnez la syntaxe exacte permettant de capturer simultanément le trafic FTP (port 21) et HTTP (port 80).

Le filtre BPF (Berkeley Packet Filter) est un mécanisme utilisé lors de la capture réseau pour sélectionner uniquement les paquets répondant à des critères précis. Il permet de réduire la quantité de trafic analysée en filtrant les paquets selon différents paramètres tels que l'adresse IP, le protocole ou le numéro de port.

L'utilisation d'un filtre BPF améliore les performances de l'analyse réseau en évitant de traiter des paquets inutiles.

Pour capturer simultanément le trafic FTP (port 21) et HTTP (port 80), la syntaxe du filtre est :
port 21 or port 80

Cette expression permet de capturer tous les paquets utilisant le port 21 ou le port 80.

2. Expliquez la différence entre une capture en mode promiscuité et une capture standard. Dans quel scénario le mode promiscuité est-il indispensable pour capturer le trafic d'une machine tierce sur un segment commuté ?

Dans une capture standard, la carte réseau reçoit uniquement les paquets qui lui sont destinés ainsi que les paquets de diffusion (broadcast).

Dans une capture en mode promiscuité, la carte réseau accepte et transmet au système d'exploitation l'ensemble des paquets qu'elle observe sur le segment réseau, même lorsqu'ils ne lui sont pas destinés.

Le mode promiscuité devient indispensable lorsqu'un administrateur ou un analyste doit observer le trafic d'une autre machine présente sur le même réseau. Toutefois, dans un réseau commuté moderne, le commutateur envoie généralement les paquets uniquement au destinataire concerné. Dans ce cas, le mode promiscuité seul n'est pas toujours suffisant et des mécanismes supplémentaires de supervision ou de duplication de trafic peuvent être nécessaires.

3. Pourquoi votre script nécessite-t-il les privilèges superutilisateur pour s'exécuter ? Répondez en vous appuyant sur le fonctionnement des sockets réseau au niveau du système d'exploitation Linux.

Sous Linux, la capture directe des paquets réseau nécessite généralement l'utilisation de sockets bas niveau permettant d'accéder aux trames circulant sur l'interface réseau.

Ces opérations sont considérées comme sensibles par le système d'exploitation puisqu'elles donnent accès aux communications réseau. Pour cette raison, Linux réserve l'accès à ces fonctionnalités aux utilisateurs disposant de privilèges élevés.

L'exécution avec les droits de superutilisateur permet donc au programme d'ouvrir les interfaces réseau en mode de capture, de recevoir les paquets bruts et d'effectuer les opérations d'analyse nécessaires. Sans ces privilèges, le système refuserait l'accès aux ressources réseau concernées.

Questions de compréhension – Partie B

1. Expliquez pourquoi l'utilisation de HTTPS (HTTP sur TLS) rend impossible l'extraction de credentials décrite dans ce TP, même si l'attaquant est présent sur le même segment réseau que la victime.

HTTPS est la version sécurisée du protocole HTTP. Il repose sur TLS (Transport Layer Security), un mécanisme de chiffrement qui protège les données échangées entre le client et le serveur.

Lorsque l'utilisateur saisit son identifiant et son mot de passe sur un site utilisant HTTPS, ces informations sont chiffrées avant leur transmission sur le réseau. Un observateur présent sur le même segment réseau peut toujours voir qu'une communication existe entre la victime et le serveur, mais il ne peut pas lire le contenu des données échangées.

Ainsi, contrairement à HTTP non sécurisé où les identifiants transitent en clair, HTTPS empêche la lecture des credentials interceptés lors d'une capture réseau passive. Cette protection repose notamment sur le chiffrement, l'intégrité des données et l'authentification du serveur grâce aux certificats numériques.

2. Le protocole FTP dispose d'une variante sécurisée nommée FTPS. Existe-t-il une autre alternative au FTP intégrant le chiffrement ? Comparez deux en termes de mécanismes de sécurité et de compatibilité avec les infrastructures existantes.

Oui. Une autre alternative sécurisée au FTP est le protocole SFTP (SSH File Transfer Protocol).

FTPS est une extension de FTP qui ajoute une couche de sécurité TLS/SSL afin de chiffrer les échanges entre le client et le serveur. Il conserve le fonctionnement général de FTP et reste compatible avec de nombreuses infrastructures existantes utilisant déjà ce protocole.

SFTP est quant à lui basé sur le protocole SSH. Contrairement à FTPS, il ne s'agit pas d'une extension de FTP mais d'un protocole différent utilisant un unique canal de communication sécurisé.

Comparaison:

Critère	FTPS	SFTP
Protocole de base	FTP + TLS/SSL	SSH
Chiffrement	TLS/SSL	SSH
Nombre de ports	Plusieurs ports	Généralement un seul port (22)
Gestion des pare-feu	Plus complexe	Plus, simple
Compatibilité avec anciens systèmes FTP	Élevée	Plus faible
Sécurité	Très bonne	Très bonne

Dans les environnements modernes, SFTP est souvent privilégié pour sa simplicité de configuration et sa meilleure intégration avec les mécanismes de sécurité basés sur SSH.

Conclusion du TP1

Ce travail pratique a permis de comprendre le fonctionnement de la capture passive de trafic sur un réseau local ainsi que les risques associés à l'utilisation de protocoles non sécurisés. L'analyse des communications en clair montre que des informations sensibles telles que les identifiants et mots de passe peuvent être exposées lorsqu'aucun mécanisme de chiffrement n'est utilisé.

Les protocoles historiques comme FTP, Telnet ou HTTP présentent aujourd'hui des limites importantes en matière de sécurité. Un individu disposant d'un accès au même segment réseau peut potentiellement observer les échanges et récupérer des données confidentielles sans modifier le trafic observé.

La généralisation des protocoles sécurisés constitue une réponse efficace à cette problématique. L'utilisation de HTTPS, FTPS, SFTP ou encore SSH permet de protéger la confidentialité des informations échangées grâce au chiffrement des communications. Même lorsqu'un tiers parvient à intercepter les paquets réseau, les données capturées demeurent illisibles sans les clés cryptographiques appropriées.

Au-delà du chiffrement, les bonnes pratiques de configuration réseau jouent également un rôle essentiel. La segmentation des réseaux, l'utilisation de commutateurs sécurisés, le contrôle des accès, la mise à jour régulière des équipements et la sensibilisation des utilisateurs contribuent à réduire considérablement les risques d'interception.

En conclusion, ce TP met en évidence l'importance fondamentale du chiffrement des communications et de l'application des bonnes pratiques de sécurité afin de garantir la confidentialité, l'intégrité et la protection des données sur les réseaux modernes.

TP2 – Empoisonnement DNS (DNS Spoofing)

Questions de compréhension

1. Qu'est-ce que DNSSEC ? Décrivez le mécanisme par lequel cette extension invalide l'attaque réalisée dans ce TP. Pourquoi son adoption reste-t-elle limitée en pratique, notamment dans les environnements d'entreprise ?

DNSSEC (Domain Name System Security Extensions) est un ensemble d'extensions de sécurité ajoutées au système DNS afin de garantir l'authenticité et l'intégrité des réponses DNS.

Son principe repose sur l'utilisation de signatures cryptographiques. Les enregistrements DNS sont signés numériquement par l'autorité responsable de la zone DNS. Lorsqu'un client reçoit une réponse DNS, il peut vérifier cette signature afin de s'assurer que les données n'ont pas été modifiées et qu'elles proviennent bien de la source légitime.

Dans le cadre de l'attaque présentée dans ce TP, une réponse DNS forgée serait rejetée car l'attaquant ne possède pas les clés privées nécessaires pour produire une signature valide. Le client détecterait alors que la réponse a été falsifiée.

Malgré ses avantages, l'adoption de DNSSEC reste limitée en raison de sa complexité de déploiement, de la gestion des clés cryptographiques, des coûts d'administration supplémentaires et de certains problèmes de compatibilité avec des infrastructures plus anciennes.

2. DNS over HTTPS (DoH) et DNS over TLS (DoT) empêchent-ils l'attaque décrite dans ce TP ?

DNS over HTTPS (DoH) et DNS over TLS (DoT) chiffrent les communications DNS entre le client et le résolveur DNS.

Lorsque le système utilise intégralement DoH ou DoT, un attaquant ne peut plus facilement observer ni modifier les requêtes DNS transitant sur le réseau local puisque celles-ci sont protégées par un canal chiffré.

Cependant, si seul le navigateur utilise DoH tandis que le système d'exploitation continue d'effectuer certaines résolutions DNS classiques, les requêtes non protégées peuvent encore être ciblées. La protection dépend donc de la manière dont les services du système sont configurés.

Ainsi, DoH et DoT réduisent fortement les risques d'empoisonnement DNS mais leur efficacité dépend de leur déploiement effectif sur l'ensemble du système.

3. Quel champ du paquet DNS garantit que votre réponse forgée sera associée à la bonne requête par le résolveur de la victime ? Que se passerait-il si ce champ ne correspondait pas ?

Le champ concerné est l'identifiant de transaction DNS, appelé « Transaction ID » ou simplement « ID ».

Chaque requête DNS est associée à un identifiant unique. Lorsqu'une réponse est reçue, le résolveur vérifie que l'identifiant de la réponse correspond à celui de la requête initialement envoyée.

Si l'identifiant ne correspond pas, la réponse est considérée comme invalide et est ignorée. Le client continuera alors d'attendre la réponse légitime provenant du serveur DNS autorisé.

4. Dans un environnement de production, quelles mesures côté commutateur ou pare-feu permettent de limiter ce type d'attaque sans nécessiter le déploiement de DNSSEC ?

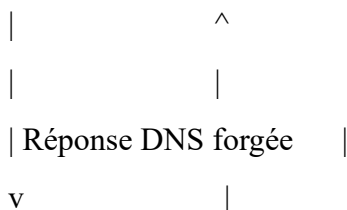
Plusieurs mesures peuvent être mises en œuvre :

- ❖ Segmentation du réseau à l'aide de VLAN.
- ❖ Filtrage des flux DNS par pare-feu.
- ❖ Restriction des serveurs DNS autorisés.
- ❖ Contrôle d'accès réseau (NAC).
- ❖ Inspection des paquets DNS par des équipements de sécurité.
- ❖ Surveillance des anomalies DNS grâce à des systèmes de détection d'intrusion.
- ❖ Limitation des redirections DNS non autorisées.

Ces mécanismes permettent de réduire les possibilités d'interception ou de falsification des réponses DNS au sein d'une infrastructure d'entreprise.

Requête DNS

Victime -----> Serveur DNS



Attaquant -----

1. La victime demande l'adresse IP d'un domaine.
2. L'attaquant intercepte la requête.
3. L'attaquant renvoie une fausse réponse avant le serveur légitime.
4. La victime utilise l'adresse IP malveillante reçue.

TP3 – Questions de compréhension générales

1. Quelle est la différence entre un ARP Request, un ARP Reply et un Gratuitous ARP ?

Un ARP Request est une requête envoyée sur le réseau afin de connaître l'adresse MAC correspondant à une adresse IP donnée.

Un ARP Reply est la réponse fournie par l'équipement possédant cette adresse IP. Il communique alors son adresse MAC au demandeur.

Un Gratuitous ARP est un message ARP envoyé spontanément sans requête préalable afin d'annoncer ou de mettre à jour une association IP/MAC.

L'empoisonnement ARP exploite généralement des messages de type ARP Reply ou Gratuitous ARP afin d'introduire de fausses associations dans les caches ARP des machines.

2. Pourquoi est-il nécessaire d'empoisonner les caches ARP de la victime ET de la passerelle ?

L'objectif est de placer l'attaquant au milieu de la communication.

Si seul le cache de la victime est modifié, les réponses de la passerelle continueront d'être envoyées directement à la victime. L'attaquant ne verra donc qu'une partie du trafic.

En modifiant simultanément les caches ARP de la victime et de la passerelle, les communications dans les deux sens transitent par l'équipement intermédiaire, permettant une observation complète des échanges.

3. Pourquoi la restauration du cache ARP en fin d'attaque est-elle une étape critique ?

Sur le plan technique, elle permet de rétablir le fonctionnement normal du réseau et d'éviter les perturbations persistantes après les tests.

Sur le plan éthique, elle démontre que l'objectif du test était uniquement pédagogique ou d'audit et non la dégradation du service. La restauration garantit le retour à l'état initial de l'environnement étudié.

4. Proposez deux architectures réseau ou configurations système qui rendraient cette attaque plus difficile à réaliser.

Premièrement, la mise en œuvre de la Dynamic ARP Inspection (DAI) sur les commutateurs gérés permet de vérifier les correspondances IP/MAC et de bloquer les messages ARP frauduleux.

Deuxièmement, l'utilisation d'une architecture Zero Trust accompagnée d'une segmentation réseau stricte réduit les possibilités de communication directe entre les équipements et limite la portée d'une éventuelle attaque locale.

D'autres mécanismes tels que l'isolation des clients Wi-Fi, le contrôle d'accès réseau (802.1X) ou les entrées ARP statiques peuvent également renforcer la sécurité.

Conclusion Générale

Les trois travaux pratiques étudiés mettent en évidence plusieurs faiblesses historiques des réseaux informatiques. Le premier TP montre que les protocoles transmettant les données en clair exposent directement les informations sensibles aux personnes capables d'observer le trafic. Le deuxième TP illustre les risques liés à l'absence de mécanismes d'authentification dans les échanges DNS traditionnels. Enfin, le troisième TP démontre les conséquences de l'absence de vérification des associations IP/MAC dans le protocole ARP.

Bien que ces techniques reposent sur des mécanismes différents, elles exploitent toutes une confiance excessive accordée aux communications internes du réseau. Dans chaque cas, l'attaquant profite d'un protocole conçu à une époque où les exigences de sécurité étaient moins élevées qu'aujourd'hui.

Les solutions modernes permettent cependant de réduire considérablement ces risques. Le chiffrement généralisé des communications grâce à TLS protège les données échangées contre l'interception. DNSSEC, DNS over HTTPS et DNS over TLS renforcent la sécurité des résolutions de noms. Les mécanismes tels que Dynamic ARP Inspection, 802.1X, la segmentation réseau et les systèmes de détection d'intrusion limitent les attaques visant l'infrastructure locale.

L'approche Zero Trust apporte une réponse particulièrement adaptée aux menaces modernes. Son principe fondamental consiste à ne faire confiance à aucun utilisateur, aucun équipement et

aucun flux réseau par défaut. Chaque accès doit être vérifié, authentifié et autorisé de manière explicite.

Grâce à cette philosophie, la surface d'attaque est fortement réduite. Même lorsqu'un acteur malveillant parvient à accéder à une partie du réseau, ses possibilités d'observation, de déplacement latéral et d'exploitation sont limitées par des contrôles de sécurité permanents.

En conclusion, ces travaux pratiques démontrent l'importance de comprendre les vulnérabilités des protocoles réseau afin de concevoir des infrastructures plus résilientes. La combinaison du chiffrement, de l'authentification, de la segmentation et du modèle Zero Trust constitue aujourd'hui l'une des meilleures stratégies pour protéger les systèmes d'information modernes.